# Trivy filesystem scan report

Converted summary of the actual Trivy JSON report. Findings are calculated directly from raw/trivy.json; no severity counts are entered manually.

Repository: https://github.com/JoeBeebz/RateMyFries

Scanned GitHub revision: b93baae14b9fefb54077c02bad7f740cb358902b

Scan started: 2026-10-20T07:20:59Z | Execution: local Docker Desktop on Windows

## 1. Tools used

Languages: Python, JavaScript, HTML/Jinja, CSS and SQLite SQL. Trivy 0.76.0. Scan type: filesystem, with dependency vulnerabilities, misconfiguration and secrets scanners enabled. Executed locally in the official Trivy container on Docker Desktop; the container image itself was not the scan target.

## 2. Required severity metrics

| Dependency vulnerability severity | Count |
|---|---|
| CRITICAL | 0 |
| HIGH | 0 |
| MEDIUM | 0 |
| LOW | 0 |
| UNKNOWN | 0 |
| Total | 0 |

Additional scanner results: 0 misconfiguration findings; 0 secret findings. No supported infrastructure configuration files were detected; this is not a container/operating-system vulnerability assessment.

## 3. Scope

The same sanitized application source and tests as the SonarQube scan, pinned requirements.txt and the fully resolved installed Python environment in resolved-environment/requirements.txt. Trivy detected 2 language dependency targets. Git history, virtual environments, instance data/secrets, reports, demo media and Sonar temporary output were excluded. License detection was skipped because site-packages was not mounted; dependency vulnerability detection completed.

## 4. Trend

Previous sprint: unavailable - no Sprint 2 Trivy report was present. This is the first recorded automated baseline. Initial and final scans during Sprint 3 both reported zero dependency vulnerabilities; no earlier sprint counts are invented.

## 5. Reflection

The main risk area is dependency drift and incomplete environmental coverage rather than a reported vulnerability in this filesystem scan. Next sprint, retain a resolved dependency inventory, rescan on PRs and scan the deployment image when an image exists.

This static analysis was generated using automated tools during this sprint.

Evidence: raw/trivy.json, raw/trivy.log, raw/trivy-version.txt, raw/requirements-resolved.txt and raw/scan-metadata.json. Tool image digests are retained in the metadata for reproducibility.